HEPIA – Haute École du Paysage, d'Ingénierie et d'Architecture

Filière ISC – Informatique et Systèmes de Communication

DOCUMENTATION TECHNIQUE COMPLÈTE

Projet SecOS-GR8

Infrastructure PME Sécurisée

Étudiants : HYSENI Riad
EL HAKOUNI Yassin

Professeur : Lionel Brocard

Cours : Sécurité des Systèmes d'Exploitation

Semestre : Printemps 2025-26

Date de rendu : 05 janvier 2026

Table des matières

1 Inventaire des Machines Virtuelles **2**
1.1 Vue d'ensemble de l'infrastructure . . . 2

2 Utilisateurs, Rôles et Mots de Passe **2**
2.1 Comptes système communs (toutes les VMs) . . . 2
2.2 Comptes spécifiques par service . . . 2
2.3 Avertissement important sur les mots de passe . . . 2
2.3.1 Politique de mots de passe recommandée pour la production . . . 3

3 Configuration Détaillée des 7 VMs avec Sécurité Avancée **3**
3.1 VM AUTH – OpenLDAP (192.168.100.139) . . . 3
3.2 VM DATA – Samba/SFTP (192.168.100.149) . . . 3
3.3 VM BACKUP – rsnapshot (192.168.100.151) . . . 4
3.4 VM VPN – WireGuard (192.168.100.153) . . . 5
3.5 VM WEB – Nginx (192.168.100.157) . . . 5
3.6 VM MAIL – Postfix/Dovecot (192.168.100.162) . . . 6
3.7 VM LOGS – rsyslog (192.168.100.176) . . . 6

4 Configuration Détaillée des 3 VMs avec Sécurité Standard **6**
4.1 VM ADMIN – Bastion SSH (192.168.100.120) . . . 7
4.2 VM DNS – Unbound (192.168.100.136) . . . 7
4.3 VM CLIENT – Poste de test (192.168.100.159) . . . 8
4.4 Comment renforcer ces 3 VMs . . . 8

5 Détails du Durcissement (7 VMs avancées) **8**
5.1 Configuration SSH durcie . . . 8
5.2 Bannière d'avertissement légal . . . 9
5.3 Configuration Fail2ban . . . 9
5.4 Durcissement Kernel (sysctl) . . . 9
5.5 Configuration Auditd . . . 10

6 Récapitulatif des Scores Lynis **10**

7 Informations de Connexion **10**
7.1 Accès SSH via le point relais . . . 10
7.2 Commandes de connexion par VM . . . 10

8 Recommandations pour la Production **11**
8.1 Chiffrement des disques (LUKS) . . . 11
8.2 Autres recommandations . . . 11

1 Inventaire des Machines Virtuelles

1.1 Vue d'ensemble de l'infrastructure

L'infrastructure comprend **10 machines virtuelles** Debian 12 (Bookworm), toutes connectées au réseau 192.168.100.0/24 avec le domaine `secos-gr8.lan`.

VM	Hostname	IP	RAM	Service	Sécurité
ADMIN	secos-gr8-admin	192.168.100.120	1 Go	SSH Bastion	Standard
DNS	secos-gr8-dns	192.168.100.136	1 Go	Unbound	Standard
AUTH	secos-gr8-auth	192.168.100.139	1 Go	OpenLDAP	**Avancée**
DATA	secos-gr8-data	192.168.100.149	2 Go	Samba/SFTP	**Avancée**
BACKUP	secos-gr8-backup	192.168.100.151	2 Go	rsnapshot	**Avancée**
VPN	secos-gr8-vpn	192.168.100.153	1 Go	WireGuard	**Avancée**
WEB	secos-gr8-web	192.168.100.157	2 Go	Nginx	**Avancée**
CLIENT	secos-gr8-client	192.168.100.159	2 Go	Xfce GUI	Standard
MAIL	secos-gr8-mail	192.168.100.162	2 Go	Postfix/Dovecot	**Avancée**
LOGS	secos-gr8-logs	192.168.100.176	2 Go	rsyslog	**Avancée**

Table 1 – Inventaire complet des 10 VMs

2 Utilisateurs, Rôles et Mots de Passe

2.1 Comptes système communs (toutes les VMs)

Utilisateur	Mot de passe	UID	Groupes	Rôle
root	admin	0	root	Super-utilisateur
sysadmin	admin	1000	sudo, adm	Administration système
user1	user123	1001	user1	Utilisateur standard
user2	user123	1002	user2	Utilisateur standard
operator	oper123	1003	adm	Opérateur (lecture logs)

Table 2 – Comptes présents sur toutes les VMs

2.2 Comptes spécifiques par service

VM	Utilisateur	Mot de passe	Service	Accès
DATA	alice	alice123	Samba/SFTP	Partage company
MAIL	mailuser1	mail123	Postfix/Dovecot	mailuser1@secos-gr8.lan
MAIL	mailuser2	mail123	Postfix/Dovecot	mailuser2@secos-gr8.lan
AUTH	cn=admin	admin	OpenLDAP	Administrateur LDAP
CLIENT	testuser	test	GUI Xfce	Tests et démonstrations

Table 3 – Comptes spécifiques par service

2.3 Avertissement important sur les mots de passe

ATTENTION : Les mots de passe utilisés sont **volontairement simples** pour faciliter les tests et démonstrations dans le cadre académique.
En environnement de production, ces mots de passe **doivent impérativement être changés** et respecter une politique de sécurité stricte.

2.3.1 Politique de mots de passe recommandée pour la production

Modifier le fichier `/etc/security/pwquality.conf` :

```
# Politique de mots de passe stricte
minlen = 12          # Minimum 12 caracteres
dcredit = -1         # Au moins 1 chiffre obligatoire
ucredit = -1         # Au moins 1 majuscule obligatoire
lcredit = -1         # Au moins 1 minuscule obligatoire
ocredit = -1         # Au moins 1 caractere special obligatoire
minclass = 3         # Au moins 3 classes de caracteres differentes
maxrepeat = 3        # Maximum 3 caracteres identiques consecutifs
dictcheck = 1        # Verification contre le dictionnaire
enforcing = 1        # Application stricte de la politique
```

Forcer le changement de mot de passe à la prochaine connexion :

```
# Forcer tous les utilisateurs a changer leur mot de passe
for user in user1 user2 operator alice sysadmin; do
    chage -d 0 $user
done
```

3 Configuration Détaillée des 7 VMs avec Sécurité Avancée

Ces serveurs ont reçu un durcissement complet avec audit Lynis (scores 77-78/100). Chaque VM dispose des outils de sécurité suivants installés et configurés : **lynis, fail2ban, auditd, libpam-pwquality, unattended-upgrades**.

3.1 VM AUTH – OpenLDAP (192.168.100.139)

Configuration	Valeur
Base DN	dc=secos-gr8,dc=lan
Admin DN	cn=admin,dc=secos-gr8,dc=lan
Mot de passe admin	admin
Score Lynis	**77/100**

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
389/tcp	TCP	LDAP	OUVERT
80, 443, 25, 53, ...	–	Autres	BLOQUÉ

Services actifs : slapd, ssh, fail2ban, auditd, rsyslog (envoi vers LOGS 192.168.100.176)

3.2 VM DATA – Samba/SFTP (192.168.100.149)

Configuration	Valeur
Partage Samba	/srv/samba/company
Groupe d'accès Samba	smbusers
Répertoire SFTP	/sftp/alice
Chroot SFTP	Activé
Score Lynis	**78/100**

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH + SFTP	OUVERT
139/tcp	TCP	NetBIOS Session	OUVERT
445/tcp	TCP	SMB Direct	OUVERT
80, 443, 25, 53, ...	–	Autres	BLOQUÉ

Configuration Samba (`/etc/samba/smb.conf`) :

```
[global]
   workgroup = SECOSGROUP
   server string = SecOS-GR8 Data Server
   security = user
   server min protocol = SMB2
   hosts allow = 192.168.100.0/24 127.0.0.1

[company]
   path = /srv/samba/company
   valid users = @smbusers
   read only = no
   create mask = 0660
   directory mask = 0770
```

3.3 VM BACKUP – rsnapshot (192.168.100.151)

Configuration	Valeur
Répertoire de stockage	/srv/backup/rsnapshot/
Rétention daily	7 sauvegardes
Rétention weekly	4 sauvegardes
Rétention monthly	3 sauvegardes
Source sauvegardée	DATA (192.168.100.149) via SSH
Score Lynis	**77/100**

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
Tous les autres	–	–	BLOQUÉ

Planification cron (`/etc/cron.d/rsnapshot`) :

```
0 2 * * *       root    /usr/bin/rsnapshot daily
0 3 * * 0       root    /usr/bin/rsnapshot weekly
0 4 1 * *       root    /usr/bin/rsnapshot monthly
```

3.4 VM VPN – WireGuard (192.168.100.153)

Configuration	Valeur
Réseau VPN	10.10.10.0/24
IP serveur VPN	10.10.10.1
Port d'écoute	51820/UDP
ip_forward	**1** (activé - requis pour VPN)
Peers configurés	Admin (10.10.10.2), User1 (10.10.10.3)
Score Lynis	**77/100**

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
51820/udp	UDP	WireGuard	OUVERT
Tous les autres	–	–	BLOQUÉ

Note : Cette VM est la seule avec `net.ipv4.ip_forward = 1` car le routage est nécessaire pour le VPN.

3.5 VM WEB – Nginx (192.168.100.157)

Configuration	Valeur
Document root	/var/www/secos-gr8
Certificat TLS	Auto-signé (TLS 1.2 et 1.3)
Redirection HTTP	Automatique vers HTTPS
HSTS	max-age=31536000 (1 an)
Score Lynis	**78/100**

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
80/tcp	TCP	HTTP (redir)	OUVERT
443/tcp	TCP	HTTPS	OUVERT
Tous les autres	–	–	BLOQUÉ

Headers de sécurité configurés :

```
add_header X-Frame-Options SAMEORIGIN;
add_header X-Content-Type-Options nosniff;
add_header Strict-Transport-Security "max-age=31536000";
```

3.6 VM MAIL – Postfix/Dovecot (192.168.100.162)

Configuration	Valeur
Domaine mail	secos-gr8.lan
Format stockage	Maildir
Réseaux autorisés	192.168.100.0/24, 127.0.0.0/8
Score Lynis	**77/100**

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
25/tcp	TCP	SMTP	OUVERT
587/tcp	TCP	Submission	OUVERT
143/tcp	TCP	IMAP	OUVERT
993/tcp	TCP	IMAPS (TLS)	OUVERT
110/tcp	TCP	POP3	OUVERT
995/tcp	TCP	POP3S (TLS)	OUVERT
Tous les autres	–	–	BLOQUÉ

3.7 VM LOGS – rsyslog (192.168.100.176)

Configuration	Valeur
Répertoire logs	/var/log/remote/%HOSTNAME%/
Rotation	14 jours, compression gzip
TLS	**Activé** (gtls) sur port 6514
Certificats	/etc/rsyslog-tls/
VMs envoyant leurs logs	AUTH, DATA, BACKUP, VPN, WEB, MAIL, ADMIN
Score Lynis	**77/100**

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
514/udp	UDP	Syslog (non chiffré)	OUVERT
514/tcp	TCP	Syslog (non chiffré)	OUVERT
6514/tcp	TCP	Syslog **TLS** (gtls)	OUVERT
Tous les autres	–	–	BLOQUÉ

4 Configuration Détaillée des 3 VMs avec Sécurité Standard

Ces serveurs disposent d'une sécurité de base mais **n'ont pas reçu le durcissement avancé** (pas de Fail2ban, Auditd, sysctl hardening). **Aucun audit Lynis n'a été réalisé** sur ces VMs.

Néanmoins, ces machines restent **significativement plus sécurisées** qu'une installation Debian par défaut grâce aux mesures suivantes appliquées :

- Pare-feu UFW actif avec politique "deny incoming" par défaut
- AppArmor activé avec profils par défaut

— Authentification SSH par clé publique configurée
— Ports strictement limités aux services nécessaires (tous les autres bloqués)

4.1 VM ADMIN – Bastion SSH (192.168.100.120)

Configuration	Valeur
Fonction	Point d'entrée pour administration
UFW	Actif, policy deny
AppArmor	Actif
SSH par clé	Configuré
Fail2ban	Non installé
Auditd	Non installé
Score Lynis	*Non audité*

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
80/tcp	TCP	HTTP	BLOQUÉ
443/tcp	TCP	HTTPS	BLOQUÉ
25/tcp	TCP	SMTP	BLOQUÉ
53/udp	UDP	DNS	BLOQUÉ
Tous les autres	–	–	BLOQUÉ

Sécurité appliquée : Seul SSH est accessible. Cette VM peut servir de rebond interne sécurisé pour accéder aux autres serveurs.

4.2 VM DNS – Unbound (192.168.100.136)

Configuration	Valeur
Zone locale	secos-gr8.lan
Type	DNS récursif avec cache
Accès autorisé	192.168.100.0/24 uniquement
UFW	Actif, policy deny
AppArmor	Actif
Score Lynis	*Non audité*

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
53/udp	UDP	DNS	OUVERT
53/tcp	TCP	DNS (zones)	OUVERT
80/tcp	TCP	HTTP	BLOQUÉ
443/tcp	TCP	HTTPS	BLOQUÉ
Tous les autres	–	–	BLOQUÉ

Sécurité appliquée : Seuls SSH et DNS sont accessibles. Le serveur DNS ne répond qu'aux requêtes du réseau interne.

4.3 VM CLIENT – Poste de test (192.168.100.159)

Configuration	Valeur
Interface graphique	Xfce
Utilisateur GUI	testuser / test
Fonction	Tests et démonstrations des services
UFW	Actif, policy deny
AppArmor	Actif
Score Lynis	*Non audité*

Ports réseau :

Port	Protocole	Service	État UFW
22/tcp	TCP	SSH	OUVERT
Tous les autres	–	–	BLOQUÉ

Outils installés : firefox-esr, smbclient, ldap-utils, nmap, wireguard-tools, thunderbird

Sécurité appliquée : Seul SSH est accessible. Cette VM est destinée aux tests, pas à héberger des services.

4.4 Comment renforcer ces 3 VMs

Pour appliquer le même niveau de sécurité que les 7 autres VMs :

```
# Installer les outils de securite
apt update && apt install -y lynis fail2ban auditd \
    libpam-pwquality unattended-upgrades

# Activer fail2ban
systemctl enable --now fail2ban

# Activer auditd
systemctl enable --now auditd

# Copier la config sysctl depuis une VM avancee
scp sysadmin@192.168.100.139:/etc/sysctl.d/99-hardening.conf /etc/sysctl.d/
sysctl -p /etc/sysctl.d/99-hardening.conf

# Lancer l'audit Lynis
lynis audit system
```

5 Détails du Durcissement (7 VMs avancées)

5.1 Configuration SSH durcie

Fichier : `/etc/ssh/sshd_config.d/hardening.conf`

```
PermitRootLogin no                    # Pas de connexion root
PasswordAuthentication yes            # A passer en 'no' en production
PermitEmptyPasswords no               # Pas de mots de passe vides
PubkeyAuthentication yes              # Authentification par cle
MaxAuthTries 3                        # 3 tentatives max
MaxSessions 3                         # 3 sessions max
LoginGraceTime 30                     # 30s pour s'authentifier
```

```
ClientAliveInterval 300                # Keepalive 5 min
ClientAliveCountMax 2                  # 2 keepalive rates = deconnexion
X11Forwarding no                       # Pas de X11
AllowAgentForwarding no                # Pas de forwarding agent
AllowTcpForwarding no                  # Pas de forwarding TCP
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,aes128-
   gcm@openssh.com
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com
KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org
AllowUsers sysadmin                    # Seul sysadmin peut se connecter
LogLevel VERBOSE                       # Logs detailles
Banner /etc/issue.net                  # Banniere d'avertissement
```

Note : `PasswordAuthentication yes` est conservé pour permettre l'accès via le point relais externe. En production, passer à `no` après déploiement complet des clés SSH.

5.2 Bannière d'avertissement légal

Fichier : `/etc/issue.net` – Affiché avant chaque connexion SSH sur les 7 VMs durcies.

```
***************************************************************************
*                            ATTENTION                                    *
*                                                                         *
* Ce systeme est reserve aux utilisateurs autorises.                      *
* Tout acces non autorise est strictement interdit et sera poursuivi      *
* conformement aux lois en vigueur.                                       *
*                                                                         *
* Toutes les activites sur ce systeme sont surveillees et enregistrees.   *
***************************************************************************
```

5.3 Configuration Fail2ban

```
# /etc/fail2ban/jail.local
[DEFAULT]
bantime = 3600          # Ban pendant 1 heure
findtime = 600          # Fenetre de 10 minutes
maxretry = 3            # 3 echecs = ban

[sshd]
enabled = true
port = ssh
```

5.4 Durcissement Kernel (sysctl)

```
# /etc/sysctl.d/99-hardening.conf
net.ipv4.ip_forward = 0                  # Desactive (1 pour VPN)
net.ipv4.tcp_syncookies = 1              # Protection SYN flood
net.ipv4.conf.all.accept_redirects = 0   # Ignore redirects
net.ipv4.conf.all.send_redirects = 0     # N'envoie pas de redirects
net.ipv4.conf.all.rp_filter = 1          # Anti-spoofing
net.ipv4.conf.all.log_martians = 1       # Log paquets suspects
net.ipv4.icmp_echo_ignore_broadcasts = 1 # Ignore broadcast ICMP
kernel.dmesg_restrict = 1                # Restreint acces dmesg
kernel.kptr_restrict = 2                 # Masque pointeurs kernel
kernel.randomize_va_space = 2            # ASLR complet
kernel.yama.ptrace_scope = 1             # Restreint ptrace
fs.suid_dumpable = 0                     # Pas de core dump SUID
fs.protected_symlinks = 1                # Protection symlinks
fs.protected_hardlinks = 1               # Protection hardlinks
```

5.5 Configuration Auditd

```
# /etc/audit/rules.d/hardening.rules
-w /etc/passwd -p wa -k identity          # Modif passwd
-w /etc/shadow -p wa -k identity          # Modif shadow
-w /etc/group -p wa -k identity           # Modif group
-w /etc/ssh/sshd_config -p wa -k sshd     # Modif SSH
-w /usr/bin/sudo -p x -k sudo             # Utilisation sudo
-w /usr/bin/su -p x -k su                 # Utilisation su
-w /sbin/insmod -p x -k modules           # Chargement modules
-w /sbin/rmmod -p x -k modules            # Dechargement modules
```

6 Récapitulatif des Scores Lynis

VM	Score	Tests	Remarque
AUTH	77/100	258	Durcissement complet
DATA	78/100	258	Durcissement complet
BACKUP	77/100	258	Durcissement complet
VPN	77/100	258	ip_forward=1 requis
WEB	78/100	258	Durcissement complet
MAIL	77/100	258	Durcissement complet
LOGS	77/100	255	Durcissement complet
Moyenne	**77.3/100**		
ADMIN	–	–	*Non audité (sécurité standard)*
DNS	–	–	*Non audité (sécurité standard)*
CLIENT	–	–	*Non audité (sécurité standard)*

Table 4 – Récapitulatif des audits Lynis

7 Informations de Connexion

7.1 Accès SSH via le point relais

```
# Connexion depuis l'exterieur du reseau
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@<IP_VM>
# Mot de passe relais : H0pH3p1AH0p!
# Mot de passe sysadmin : admin

# Connexion directe entre VMs (cles SSH deployees)
ssh sysadmin@192.168.100.XXX   # Sans mot de passe
```

7.2 Commandes de connexion par VM

```
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.120  # ADMIN
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.136  # DNS
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.139  # AUTH
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.149  # DATA
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.151  # BACKUP
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.153  # VPN
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.157  # WEB
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.159  # CLIENT
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.162  # MAIL
ssh -o ProxyJump=relay@100.64.0.107 sysadmin@192.168.100.176  # LOGS
```

8 Recommandations pour la Production

8.1 Chiffrement des disques (LUKS)

Non implémenté dans ce projet : Le chiffrement LUKS n'a pas été activé sur les VMs afin de faciliter l'administration, les redémarrages automatiques et l'accès via la console Proxmox dans le cadre académique. En production, le chiffrement des disques est **fortement recommandé** pour protéger les données au repos.

Pourquoi chiffrer les disques ?

- Protection des données en cas de vol physique du serveur
- Conformité aux réglementations (RGPD, LPD suisse)
- Protection contre l'accès non autorisé aux disques hors-ligne

Installation avec chiffrement LUKS (Debian 12) :

Lors de l'installation Debian, sélectionner :

```
Partitioning method: Guided - use entire disk and set up encrypted LVM
```

Vérification du chiffrement sur un système existant :

```
# Verifier si LUKS est actif
lsblk -f | grep crypto
cryptsetup status /dev/mapper/<nom_volume>

# Lister les volumes chiffres
dmsetup ls --target crypt
```

Note : Le chiffrement LUKS nécessite la saisie d'un mot de passe au démarrage, ce qui empêche les redémarrages automatiques sans intervention. Des solutions comme Clevis/Tang (Network Bound Disk Encryption) permettent le déverrouillage automatique sécurisé en production.

8.2 Autres recommandations

1. **Changer tous les mots de passe** avec politique stricte (12+ caractères, complexité)
2. **Désactiver PasswordAuthentication** dans SSH après déploiement complet des clés
3. **Restreindre SSH inter-VMs** uniquement aux connexions nécessaires (BACKUP → DATA)
4. **Appliquer le durcissement avancé** aux 3 VMs standard (ADMIN, DNS, CLIENT)
5. **Migrer les clients rsyslog vers TLS** (le serveur LOGS est déjà configuré sur port 6514)
6. **Intégrer une PKI** pour remplacer les certificats auto-signés
7. **Déployer un SIEM** pour l'analyse automatisée des logs centralisés

---

Genève, le 05 janvier 2026 – **HYSENI Riad & EL HAKOUNI Yassin** – Groupe 8